

DPDP COMPLIANCE AUDIT

finance-data-processing

Digital Personal Data Protection Act 2023



Grade A — Strong

Scanned: 08 April 2026

Files indexed: 14

Languages: express, pg, jsonwebtoken, bcryptjs, express-validator, swagger-ui-express

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user PII including name, email, and hashed passwords, as well as financial transaction data. The primary DPDP risk lies in the potential for unauthorized access to user credentials and financial records due to the sensitive nature of the data processed.

Total findings: 13

HIGH: 1

MEDIUM: 2

INFO: 4

PASS: 4

Tech Stack: express, pg, jsonwebtoken, bcryptjs, express-validator

Risk Profile: The application collects user PII including name, email, and hashed passwords, as well as financial transaction data. The primary DPDP risk lies in the potential for unauthorized access to user credentials and financial records due to the sensitive nature of the data processed.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	7.0/10 (70%)	WARN
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 1.1–4.2 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: password, email, address

users.js → userController.js → database.js

Flow 2: Application Logs

PII fields: password, email

auth.js → authController.js → database.js

Rule	Section	Severity	File
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/routes/users.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	src/routes/auth.js
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	src/controllers/auth Controller.js
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	src/routes/records.js
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	src/routes/auth.js

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (1–4 hours)

Fix immediately — these represent the highest legal exposure.

- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (4–16 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 9–34 hours (1.1–4.2 engineering days)

Changes Since 2026-04-08

— 13 finding(s) unchanged

Details

Finding 1 of 13

[Section 13 — Grievance Redressal]

1. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A

Estimated fix time: 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route **and** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The absence of a designated Grievance Officer means individuals have no clear channel to raise concerns or complaints regarding data processing, potentially leading to unresolved issues and a lack of accountability.

Fix:

1. Create a new route (e.g., `/contact/grievance`) that clearly displays contact information for the Grievance Officer.
2. Add a dedicated email address for grievance submissions (e.g., `grievance@yourcompany.com`).
3. Update the website's footer or a dedicated privacy/contact page to link to this new grievance route or display the contact information prominently.
4. Ensure this contact information is easily discoverable by data subjects.

DPDP:

Section 13 — Grievance Redressal — requires the data controller to appoint a Grievance Officer to handle data subject complaints.

Example:

```
const express = require('express'); const router = express.Router(); router.get('/grievance',  
(req, res) => { res.json({ message: 'For any data protection grievances, please contact our  
Grievance Officer.', email: 'grievance@yourcompany.com' }); }); module.exports = router;
```

Finding 2 of 13

[Section 8(4) — Audit Trail]

2. [MEDIUM] AUDIT_TRAIL_PARTIAL — N / A**Estimated fix time:** 2–8 hours

Partial audit trail detected. Found: change tracking. Missing: access logging, audit model.

Risk:

Without a comprehensive audit trail, it is impossible to track who accessed or modified personal data, when, and what changes were made, hindering accountability and making it difficult to investigate potential breaches or misuse.

Fix:

1. Implement middleware to log all API requests, capturing user ID, timestamp, endpoint, and HTTP method.
2. Define a database schema for audit logs, including fields for timestamp, user ID, action type (e.g., 'CREATE', 'READ', 'UPDATE', 'DELETE'), target resource, and details of the change.
3. Modify controllers to record relevant actions (especially those involving PII) into the audit log table.
4. Ensure logs are stored securely and retained according to policy.

DPDP:

Section 8(4) — Audit Trail — mandates the maintenance of an audit trail for all processing activities involving personal data.

Example:

```
const pool = require('../config/database'); const logAudit = async (userId, action, resource, details) => { await pool.query( 'INSERT INTO audit_logs (user_id, action, resource, details) VALUES ($1, $2, $3, $4)', [userId, action, resource, details] ); }; // Example usage in a controller: // const userId = req.user.id; // Assuming user is authenticated // await logAudit(userId, 'UPDATE', 'user', JSON.stringify(changes));
```

Finding 3 of 13

[Section 8 — Data Principal Rights]

3. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: src/config/database.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Incomplete deletion of personal data violates data subject rights and DPDP obligations, potentially leading to continued unauthorized processing and legal non-compliance.

Fix:

1. Identify all locations where user PII is stored, including databases, logs, backups, and any third-party services.
2. Implement a robust 'delete user' function that ensures PII is irrecoverably removed from all these locations.
3. For data that cannot be immediately deleted (e.g., due to legal retention requirements), implement anonymization or pseudonymization techniques.
4. Update `src/config/database.js` or related data access layers to ensure deletion logic is consistently applied across all data stores.

DPDP:

Section 8 — Data Principal Rights — requires that personal data be erased upon request, subject to legal obligations.

Example:

```
const pool = require('./database'); async function deleteUserCompletely(userId) { const client
= await pool.connect(); try { await client.query('BEGIN'); // Example: Delete from users table
await client.query('DELETE FROM users WHERE id = $1', [userId]); // Example: Delete related
data in other tables await client.query('DELETE FROM user_profiles WHERE user_id = $1',
[userId]); // Add more delete statements for all PII locations await client.query('COMMIT'); }
catch (e) { await client.query('ROLLBACK'); throw e; } finally { client.release(); } }
```

Finding 4 of 13

[Section 8(6) — Breach]

4. [LOW] NO_BREACH_ALERTING — N / A

Estimated fix time: 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a data breach notification mechanism means that data subjects and the relevant authorities may not be informed in a timely manner about breaches, hindering their ability to mitigate harm and comply with regulatory requirements.

Fix:

1. Develop a clear policy outlining the criteria and procedures for identifying and reporting data breaches.
2. Implement a system to log and track all suspected and confirmed data breaches.
3. Define a process for notifying affected data subjects and the supervisory authority within the legally mandated timeframe (e.g., 72 hours for the authority).
4. Consider integrating with a security monitoring service that can detect and alert on potential breaches.

DPDP:

Section 11 — Data Breach Notification — requires data controllers to notify the supervisory authority and affected data subjects in the event of a personal data breach.

Example:

```
const notifyAuthority = async (breachDetails) => { // Placeholder for actual notification
  logic to the supervisory authority console.log('Notifying authority about breach:',
  breachDetails); // In a real implementation, this would involve API calls or secure email. };
const notifyDataSubjects = async (affectedUsers, breachDetails) => { // Placeholder for
  sending notifications to affected users console.log('Notifying data subjects:', affectedUsers,
  breachDetails); // This could involve email, SMS, or in-app notifications. };
const handleDataBreach = async (breachDetails) => { await notifyAuthority(breachDetails); const
  affectedUsers = await findAffectedUsers(breachDetails.data); await
  notifyDataSubjects(affectedUsers, breachDetails); };
```

Finding 5 of 13

[Section 11 — Data Portability]

5. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data portability feature means individuals cannot easily obtain their personal data from the system in a usable format, which is a direct violation of their rights under DPDP Section 11.

Fix:

1. Create a new Express route (e.g., '/api/data-export') that handles GET requests.
2. Implement controller logic to fetch all personal data associated with the authenticated user from the database.
3. Format the fetched data into a commonly used, machine-readable format such as JSON or CSV.
4. Set appropriate Content-Disposition headers to prompt the user to download the file.

DPDP:

Section 11(1) — Data Portability requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format.

Example:

```
const express = require('express'); const router = express.Router(); const { authenticate } = require('../middleware/auth'); const userDataService = require('../services/userDataService');  
// Assume this service fetches user data router.get('/data-export', authenticate, async (req, res, next) => { try { const userId = req.user.id; // Assuming user ID is available from auth middleware const userData = await userDataService.exportUserData(userId);  
res.setHeader('Content-Type', 'application/json'); res.setHeader('Content-Disposition', 'attachment; filename="user_data.json"); res.status(200).send(JSON.stringify(userData)); } catch (error) { next(error); } }); module.exports = router;
```

Finding 6 of 13

[Section 7 — Legitimate Use]

6. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / routes / users.js

Internal file (users.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 7 of 13

[Section 5 — Notice]

7. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 8 of 13

[Section 5 — Purpose Limitation]

8. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 9 of 13

[Section 16 — Cross-Border Transfer]

9. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 10 of 13

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — src / routes / auth.js

Framework auth/consent middleware detected in this file.

Finding 11 of 13

[Section 6(6) — Consent Withdrawal]

11. [PASS] CONSENT_WITHDRAWAL_PRESENT — src / controllers / authController.js

Consent withdrawal mechanism detected. Found in: src/controllers/authController.js (line 74)

Finding 12 of 13

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — src / routes / records.js

Data deletion mechanism detected. Found 2 deletion endpoint(s) and 7 deletion signal(s). Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 13 of 13

[Section 11 — Right to Access]

13. [PASS] DATA_ACCESS_PRESENT — src / routes / auth.js

Data access endpoint detected for authenticated users.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No age verification for new accounts

Confidence: 60%

Section 9 Children

The `POST /api/auth/register` endpoint in `src/routes/auth.js` and `src/controllers/authController.js` collects user name and email but does not include any mechanism to verify the age of the user, which is a requirement for processing data of minors.

Recommendation: Implement an age verification step during user registration. This could involve asking for date of birth and checking if the user is below the age of majority, or integrating with a third-party age verification service.

[AI-INFERRED] Unclear PII usage in admin views

Confidence: 40%

Section 5 Purpose

The ``GET /api/users`` endpoint retrieves user data including ``id``, ``name``, ``email``, ``status``, ``role`` from the ``users`` table. While this might be for administrative purposes, the specific purpose for accessing this PII is not explicitly defined or restricted, potentially violating the purpose limitation principle if used for reasons beyond initial collection.

Recommendation: Add explicit checks or logging to document the purpose for which user data is accessed via ``GET /api/users``. Consider role-based access control to limit which roles can view specific PII fields.

[AI-INFERRED] No DPO contact information exposed

Confidence: 25%

Section 10 DPO

There is no mention or exposure of a Data Protection Officer (DPO) contact within the provided code context, which is a requirement for certain organizations under DPDP.

Recommendation: Add a publicly accessible contact point for the Data Protection Officer. This could be a dedicated email address or a contact form, potentially linked from a privacy policy page (which is not visible in the provided context).